Apostila Didática Cisco CyberOps: Módulos 9, 10 e 11

Resumo estruturado para alunos com acompanhamento dos tópicos oficiais Cisco e dicionários instrucionais.

> **Guia do Estudante de Cibersegurança Cisco**
> Este documento foi preparado como material didático especializado para apoiar o estudo dos Módulos 9, 10 e 11 do curso Cisco CyberOps (Defesa de Rede). O conteúdo segue a ordem lógica dos tópicos do programa e apresenta ao final de cada módulo um Dicionário Instrucional de Termos para fixação dos conceitos-chave de monitoramento, análise de dados e avaliação de alertas.

Módulo 9: Tecnologias e Protocolos de Rede

O Módulo 9 analisa a infraestrutura de protocolos de rede sob a perspectiva do monitoramento e da segurança da informação. Em redes corporativas, o conhecimento aprofundado dos protocolos padrão da camada de aplicação e transporte permite ao analista identificar anomalias e comportamentos atípicos de tráfego.

9.1 Protocolos Comuns de Monitoramento e Aplicação

Syslog e NTP (Network Time Protocol)

O monitoramento eficaz de uma rede depende do registro estruturado de eventos e da sincronização precisa de horários entre todos os ativos de TI.

- **Syslog:** Padrão universal de mensagens utilizado para registrar eventos gerados por dispositivos de rede e computadores (porta UDP 514).
- **Centralização de Logs:** Permite centralizar a coleta de registros em um servidor central (daemon syslog), facilitando a auditoria e análise de segurança.
- **NTP:** Protocolo que opera na porta UDP 123 para sincronizar o relógio dos ativos de rede com fontes de tempo autoritativas (hierarquia Stratum).
- **Sincronização Temporal:** Sem o NTP, os carimbos de data/hora (timestamps) dos logs do Syslog seriam inconsistentes, impedindo a correlação de eventos entre múltiplos dispositivos.

DNS (Domain Name System)

O DNS traduz nomes de domínio amigáveis em endereços IP numéricos. Como o tráfego DNS é liberado na maioria das redes, ele exige atenção especial do analista.

- **DNS Tunneling e Exfiltração:** Técnica na qual dados não autorizados são encapsulados em consultas e respostas DNS legítimas utilizando subdomínios codificados.

- **Comunicação Externa DNS:** Sistemas infectados podem consultar servidores DNS externos para receber comandos de comunicação e controle de forma discreta.
- **Proteção DNS:** Soluções como o Cisco Umbrella analizam padrões de comprimento de subdomínio, frequência de consultas e reputação de domínios para bloquear abusos.

HTTP e HTTPS (Hypertext Transfer Protocol / Secure)

HTTP e HTTPS representam o tráfego dominante na Web corporativa:

- **HTTP:** Protocolo em texto simples sem criptografia. Suscetível a interceptação ou injeção de conteúdos (ex.: iFrame invisível que carrega recursos não autorizados).
- **HTTPS:** Utiliza criptografia SSL/TLS para proteger o tráfego HTTP. Garante confidencialidade e integridade dos dados durante a navegação.
- **Desafio de Monitoramento:** A criptografia do HTTPS impede a inspeção direta de conteúdo pelos dispositivos de rede tradicionais, exigindo inspeção dedicada SSL/TLS.

Protocolos de E-mail (SMTP, POP3 e IMAP)

O e-mail é um dos principais canais de comunicação de uma organização e vetor constante de mensagens não solicitadas.

- **SMTP:** Protocolo padrão para o envio e transporte de mensagens de e-mail entre servidores.
- **POP3 e IMAP:** Protocolos de acesso utilizados pelos clientes para baixar e visualizar e-mails armazenados.
- **Segurança de E-mail:** O monitoramento de e-mail por soluções como o Cisco ESA analisa anexos, reputação de remetentes e links no corpo das mensagens.

ICMP (Internet Control Message Protocol)

Utilizado para mensagens de erro e diagnósticos operacionais (ferramentas ping e traceroute).

- **Mapeamento de Rede:** Varreduras de ping (ping sweeps) são usadas para mapear hosts ativos e identificar a estrutura de sub-redes.
- **Tunneling ICMP:** O campo de dados do pacote ICMP pode ser utilizado indevidamente para transportar dados não autorizados (ICMP tunneling).

9.2 Tecnologias de Segurança da Infraestrutura

Listas de Controle de Acesso (ACLs)

- **ACLs:** Regras configuradas em roteadores para permitir ou negar pacotes com base em IPs, portas e protocolos de origem/destino.
- **Atuação das ACLs:** Filtram pacotes, mas não analisam o conteúdo interno. Precisam operar integradas a Firewalls NGFW e IPS.

NAT e PAT (Network / Port Address Translation)

- **NAT/PAT:** Mapeamento de endereços IP privados para endereços IP públicos, preservando o espaço de endereçamento IPv4.

- **Análise de Logs:** Como o NAT altera os endereços IP de origem na borda, a equipe do SOC deve correlacionar os registros de tradução NAT para identificar o host interno correspondente.

Criptografia, Encapsulamento e VPNs

- **VPNs:** Criam túneis seguros de comunicação sobre redes públicas, garantindo confidencialidade e integridade através de criptografia forte.

Redes Ponto a Ponto (P2P) e Tor

- **Redes P2P:** Aplicações P2P transferem arquivos diretamente entre computadores, sem servidor central. Apresentam riscos de contaminação por softwares não homologados.
- **Tor:** Rede de roteadores que utiliza criptografia em camadas (onion routing) para anonimizar o tráfego Web, exigindo monitoramento rigoroso.

Balanceamento de Carga (Load Balancing)

- **Load Balancing / LBM:** Distribui o tráfego entre múltiplos servidores para otimizar desempenho. Os dispositivos LBM realizam verificações periódicas que geram tráfego sintético nos logs de rede.

Dicionário Instrucional de Termos — Módulo 9

Termo / Sigla	Definição Didática	Contexto de Aplicação em Redes/Segurança
Syslog	Protocolo padrão para envio e centralização de logs de eventos em redes (UDP 514).	Consolidação de registros de firewalls e roteadores em um servidor centralizado.
NTP	Network Time Protocol (UDP 123). Protocolo para sincronização de relógios em ativos de TI.	Garantir a exatidão do carimbo de data/hora (timestamp) nos logs de múltiplos dispositivos.
DNS Tunneling	Técnica que encapsula dados não-DNS dentro de consultas e respostas DNS legítimas.	Extração não autorizada de dados ou recepção de comandos contornando controles de borda.
iFrame Injection	Inserção de um quadro HTML invisível em páginas Web para carregar recursos externos.	Forçar o navegador do usuário a acessar páginas não autorizadas.
SSL/TLS	Protocolos de criptografia de transporte que garantem privacidade e integridade no tráfego HTTPS.	Proteção de dados em trânsito; exige inspeção dedicada em dispositivos de segurança.
SMTP / POP3 / IMAP	Protocolos padrão para envio (SMTP) e recebimento/download (POP3/IMAP) de e-mails.	Monitoramento do fluxo de e-mails corporativos e filtragem por soluções como o Cisco ESA.
ICMP Tunneling	Encapsulamento de dados arbitrários dentro de mensagens de controle ICMP.	Burlar regras de firewall que permitem tráfego ICMP sem inspeção profunda de conteúdo.

ACL	Access Control List. Regras para permissão ou bloqueio de pacotes com base em IPs e portas.	Filtragem inicial de tráfego não autorizado em roteadores e firewalls.
NAT / PAT	Tradução de endereços IP privados internos para endereços IP públicos globais.	Economia de IPs; exige correlação de logs de tradução para identificar hosts internos.
Tor	The Onion Router. Rede de roteadores para navegação anônima com criptografia em camadas.	Ocultamento da origem de tráfego e acesso a canais anônimos.
Load Balancer (LBM)	Dispositivo que distribui requisições entre múltiplos servidores de aplicação.	Otimização de disponibilidade; gera tráfego de sondagem que deve ser reconhecido pelo SOC.

Módulo 10: Dados de Segurança de Rede

O Módulo 10 aborda os tipos de dados coletados e examinados pelas equipes de segurança. No SOC, esses dados fornecem a visibilidade necessária para detectar anomalias, investigar incidentes e reconstruir eventos de rede.

10.1 Tipos de Dados de Segurança

- **Dados de Alerta:** Mensagens geradas por sensores NIDS/IPS (ex.: Snort) ao identificar a correspondência com uma regra ou assinatura de segurança.
- **Dados de Sessão e Transação:** Registros de conversas entre dois endpoints da rede, identificados principalmente pelas 5-tuplas e logs de conexões (ex.: Zeek).
- **Capturas de Pacotes Completos (PCAP):** Gravação integral dos pacotes transmitidos (arquivos PCAP capturados via Wireshark ou tcpdump) para forense detalhada.
- **Dados Estatísticos:** Métricas e estatísticas sobre padrões de tráfego (NetFlow, IPFIX, NBAD) para identificar desvios do comportamento normal.

10.2 Logs de Dispositivo Final (Hosts e Servidores)

Logs do Sistema Operacional Windows

Os eventos no Windows dividem-se em cinco categorias principais:

- **Logs de Aplicativos:** Eventos gerados por programas e softwares de usuário.
- **Logs do Sistema:** Eventos do sistema operacional, drivers de dispositivo e hardware.
- **Logs de Instalação:** Registros de instalação de pacotes e atualizações do sistema.
- **Logs de Segurança:** Registros de auditoria, eventos de logon (sucesso/falha) e acesso a arquivos.
- **Logs de Linha de Comando:** Registro da execução de comandos em linha de comando por processos.

Possuem níveis de severidade padronizados: Erro, Aviso, Informações, Auditoria de Sucesso e Auditoria de Falha.

Syslog e Estrutura de Mensagens

As mensagens Syslog contêm três partes: PRI (Prioridade), HEADER (Data/Hora e Host) e MSG (Conteúdo).

- **Valor PRI:** Calculado pela fórmula: PRI = (Facility * 8) + Severity, onde Facility indica a categoria de origem e Severity a gravidade.
- **Níveis de Severidade (0 a 7):** Varia de 0 (Emergência) a 7 (Depuração/Debug). Severidades de 0 a 3 indicam condições de erro ou emergência.

Logs de Servidores e Proxies

- **Logs de Servidores Web:** Registram requisições HTTP/HTTPS, códigos de resposta (200, 404, 500) e métodos de acesso (servidores Apache e IIS).
- **Logs de Proxy:** Registram conexões saintes de usuários para a Web, permitindo auditoria de domínios e navegação (ex.: Cisco Umbrella).

10.3 Logs de Rede e Dispositivos Avançados

SIEM e SOAR

- **SIEM:** Combina gerenciamento de eventos em tempo real (SEM) e análise de informações de longo prazo (SIM). Centraliza e correlaciona registros de múltiplos fabricantes (ex.: Splunk).
- **SOAR:** Plataforma para automação de fluxos de resposta a incidentes de segurança.

Tcpdump, Wireshark e NetFlow

- **Tcpdump:** Utilitário de linha de comando para captura de pacotes em tempo real com base na biblioteca libpcap.
- **NetFlow / IPFIX:** Tecnologia Cisco que coleta metadados sobre fluxos IP com base em 5 a 7 atributos principais, sem gravar o conteúdo bruto dos pacotes.

Soluções de Segurança Cisco (AVC, ESA, WSA, NGFW)

- **Cisco AVC:** Utiliza o NBAR2 para classificar aplicações da camada 7 (Skype, P2P, Webex) independentemente da porta utilizada.
- **Cisco ESA / WSA:** Dispositivos especializados para filtragem de reputação e inspeção de e-mails (ESA) e tráfego Web (WSA).
- **Cisco NGFW (Firepower):** Firewalls com inspeção profunda, controle de aplicações e recursos de prevenção de intrusão (NGIPS e AMP).

Dicionário Instrucional de Termos — Módulo 10

Termo / Sigla	Definição Didática	Contexto de Aplicação em Redes/Segurança

5-Tupla	Conjunto de 5 elementos: IP Origem, IP Destino, Porta Origem, Porta Destino e Protocolo.	Base para identificação de sessões de tráfego em firewalls e analisadores.
PCAP	Packet Capture. Arquivo com gravação integral de pacotes transmitidos na rede.	Análise forense detalhada de conexões no Wireshark.
NetFlow / IPFIX	Tecnologia que gera estatísticas e metadados sobre fluxos de tráfego IP.	Mapeamento de perfil de tráfego e detecção de anomalias volumétricas.
Facility (Syslog)	Código numérico que indica o subsistema gerador da mensagem de log.	Classificação e filtragem de logs por tipo de serviço no servidor syslog.
Severity (Syslog)	Nível de gravidade da mensagem de log, variando de 0 (Emergência) a 7 (Debug).	Priorização de alertas críticos para análise imediata pela equipe do SOC.
SIEM	Security Information and Event Management. Sistema centralizado de correlação de logs.	Correlacionar eventos de múltiplos dispositivos para detectar incidentes.
SOAR	Security Orchestration, Automation and Response. Plataforma de automação de respostas.	Execução de rotinas automáticas de contenção ao confirmar um incidente.
NBAR2	Motor de reconhecimento de aplicações da camada de aplicação da Cisco.	Identificar tráfego de aplicações específicas independentemente da porta usada.
Cisco ESA / WSA	Email Security Appliance e Web Security Appliance da Cisco.	Proteção especializada contra ameaças corporativas via e-mail e navegação Web.
Cisco NGFW / Firepower	Next-Generation Firewall da Cisco com inspeção de contexto e prevenção de intrusão.	Proteção de borda com controle de aplicações, NGIPS e análise de reputação.

Módulo 11: Avaliação e Classificação de Alertas

O Módulo 11 aborda o processo de triagem e investigação de alertas em um SOC. O analista deve qualificar os alertas para distinguir eventos benignos de incidentes reais de segurança.

11.1 Fontes de Alertas e o Ecossistema Security Onion

O Security Onion é uma distribuição Linux open-source focada em Monitoramento de Segurança de Rede (NSM) que integra diversas ferramentas:

Ferramentas de Coleta e Detecção

- **Snort:** Sistema NIDS baseado em assinaturas de regras para inspeção de rede.
- **Zeek (Bro):** NIDS comportamental que gera logs estruturados sobre protocolos de aplicação.
- **Suricata:** Motor NIDS/NIPS multithread de alto desempenho.
- **OSSEC / Wazuh:** Sistemas HIDS para monitoramento de integridade em hosts.
- **CapME:** Interface para visualização de capturas PCAP renderizadas.

Ferramentas de Análise e Visualização

- **Sguil:** Console de gerenciamento de alertas no Security Onion, organizando alertas por prioridade e cores.
- **Kibana:** Interface visual para pesquisas interativas e criação de painéis analíticos.

Estrutura das Regras do Snort

Composta pelo Cabeçalho da Regra (ação, protocolo, IPs/portas, direção) e Opções da Regra (msg, content, sid, rev).

- **Cabeçalho da Regra:** Ação (alert), protocolo (tcp/udp/ip), origem e destino. Exemplo: alert tcp $EXTERNAL_NET any -> $HOME_NET 80
- **Opções da Regra:** Parâmetros entre parênteses contendo mensagem de alerta (msg), padrão textual (content), ID da regra (sid) e revisão (rev).
- **Fontes de Regras:** Regras GPL (comunitárias), ET (Emerging Threats) e VRT (Cisco Talos).

11.2 Processo de Avaliação e Classificação de Alertas

Matriz de Classificação de Alertas

- **Verdadeiro Positivo (TP):** Alerta disparado corretamente para um evento crítico real. Requer ação de resposta.
- **Falso Positivo (FP):** Alerta disparado para tráfego legítimo ou benigno. Requer ajuste (tuning) da regra.
- **Verdadeiro Negativo (TN):** Tráfego normal que não gerou alerta. Condição ideal e esperada.
- **Falso Negativo (FN):** Ocorreu um evento crítico, mas nenhum alerta foi gerado. Cenário que exige revisão das regras de detecção.

Análise Determinística vs. Análise Probabilística

- **Análise Determinística:** Avaliação baseada em regras exatas e assinaturas conhecidas. Determina o resultado com base em critérios objetivos.
- **Análise Probabilística:** Avaliação baseada em modelos estatísticos para calcular a probabilidade de um evento sob incerteza.

Dicionário Instrucional de Termos — Módulo 11

Termo / Sigla	Definição Didática	Contexto de Aplicação em Redes/Segurança

Security Onion	Distribuição Linux open-source para monitoramento de segurança de rede e análise de logs.	Plataforma integrada de ferramentas para treinamento e operação em SOC.
Sguil	Console gráfico do Security Onion para triagem e análise de alertas por analistas Nível 1.	Visualização e priorização de alertas de segurança em tempo real.
Snort	Motor NIDS/NIPS baseado em assinaturas para detecção de anomalias em tráfego de rede.	Inspeção de pacotes e disparo de alertas com base em regras configuradas.
Zeek (Bro)	Plataforma de monitoramento de rede baseada em análise comportamental de sessões.	Geração de registros de transação estruturados sobre protocolos de aplicação.
Verdadeiro Positivo (TP)	Classificação de alerta que identificou corretamente uma condição real de risco.	Confirmação de incidente e início do procedimento de contenção.
Falso Positivo (FP)	Alerta gerado incorretamente por tráfego benigno ou legítimo.	Ajuste e refinamento (tuning) das regras do IDS para reduzir o ruído nos alertas.
Falso Negativo (FN)	Condição não autorizada que ocorreu na rede sem gerar alerta de segurança.	Revisão das assinaturas e criação de novas regras de detecção no IDS.
SID (Snort ID)	Identificador numérico exclusivo atribuído a cada regra do Snort.	Localização exata da regra responsável pelo disparo no banco de assinaturas.
Análise Determinística	Avaliação baseada em critérios exatos, padrões rígidos e assinaturas conhecidas.	Verificação objetiva de correspondência com uma regra do IDS.
Análise Probabilística	Avaliação baseada em cálculo estatístico de probabilidade e estimativa de risco.	Identificação de comportamentos anômalos em tráfego de rede sem assinatura prévia.

Conclusão e Orientação para os Alunos

O domínio dos Módulos 9, 10 e 11 fornece a sustentação essencial para a atuação prática como Analista de Cibersegurança Tier 1. Recomendamos aos alunos a realização dos laboratórios práticos do curso, aplicando o conhecimento destes conceitos na análise de logs e na triagem de alertas reais.